



Figure 11: Stage view of the project

ZAP Scanning Report

Summary of Alerts	
Risk Level	Number of Alerts
High	0
Medium	1
Low	4
Informational	0

Alert Detail	
Medium (Medium)	X-Frame-Options Header Not Set
Description	X-Frame-Options header is not included in the HTTP response to protect against 'Clickjacking' attacks.
URL	https://nitfeedback.herokuapp.com/
Method	GET
Parameter	X-Frame-Options
Instances	1
Solution	Most modern Web browsers support the X-Frame-Options HTTP header. Ensure it's set on all web pages returned by your site (if you expect the page to be framed only by pages on your server (e.g. it's part of a FRAMESET) then you'll want to use SAMEORIGIN, otherwise if you never expect the page to be framed, you should use DENY. ALLOW-FROM allows specific websites to frame the web page in supported web browsers).
Reference	http://blogs.msdn.com/ieinternals/archive/2010/03/30/combating-clickjacking-with-x-frame-options.aspx
CWE Id	16

Figure 12: Report on the scan conducted on the Web application

Medium (Medium)	X-Frame-Options Header Not Set
Description	X-Frame-Options header is not included in the HTTP response to protect against 'Clickjacking' attacks.
URL	https://nitfeedback.herokuapp.com/
Method	GET
Parameter	X-Frame-Options
Instances	1
Solution	Most modern Web browsers support the X-Frame-Options HTTP header. Ensure it's set on all web pages returned by your site (if you expect the page to be framed only by pages on your server (e.g. it's part of a FRAMESET) then you'll want to use SAMEORIGIN, otherwise if you never expect the page to be framed, you should use DENY. ALLOW-FROM allows specific websites to frame the web page in supported web browsers).
Reference	http://blogs.msdn.com/ieinternals/archive/2010/03/30/combating-clickjacking-with-x-frame-options.aspx
CWE Id	16
WASC Id	15

Figure 13: Description of vulnerability and proposed solution

References

- Security Concerns and Best Practices for Automation of Software Deployment Processes: An Industrial Case Study by Vaishnavi Mohan, Lotfi ben Othmane and Andre Kres, IEEE Secure Development Conference, 2018, pp:21-28.
- Penetration Testing as a Service powered by certified hackers and artificial intelligence, available at <https://www.breachlock.com/>
- Introduction to OWASP ZAP; <https://www.zaproxy.org/>

By: Akhilank M.J. Kaipu and B. Thangaraju

The authors are associated with the open source technology lab in the International Institute of Information Technology, Bengaluru.